

## TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

### INVENTARIO DEI FORNITORI ICT

Area 08 – Sistema Informativo

| Codice                  | Revisione              | Data                     | Pagine    |
|-------------------------|------------------------|--------------------------|-----------|
| <b>TD-SGI-MOD182_00</b> | 00                     | 29/04/2026               | 4         |
| Redatto da              | Approvato da           | Classificazione          | Stato     |
| IT Manager / RSGI       | AD – Francesco Epifani | Riservato Alta Direzione | In vigore |

| Responsabile del Documento | RSGI           | Emissione del Documento |
|----------------------------|----------------|-------------------------|
| Francesco Epifani          | Iacopo Cupelli | Francesco Epifani       |
| 29/04/2026                 | 29/04/2026     | 29/04/2026              |

**Toscana Diagnostica S.r.l.**

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.  
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

## 1. Scopo e ambito di applicazione

Il presente modulo costituisce l'inventario di tutti i fornitori ICT di Toscana Diagnostica S.r.l., articolato per criticità ai fini della Direttiva NIS2 e del D.Lgs. 138/2024. È mantenuto dall'IT Manager con la supervisione del RSGI in attuazione della TD-SGI-PRO070\_00 §8.

L'inventario alimenta direttamente la qualificazione dei fornitori ICT critici, la pianificazione degli audit di terza parte, il monitoraggio della catena di fornitura e la gestione del rischio di compromissione di supply-chain (NIS2 art. 24 c. 2 lett. d).

Il riesame complessivo dell'inventario è almeno annuale (entro il 31 marzo di ogni anno) e in occasione di ogni nuovo contratto, rinnovo o cessazione di rapporti con fornitori ICT.

## 2. Riferimenti

| Riferimento                            | Ambito                                         |
|----------------------------------------|------------------------------------------------|
| D.Lgs. 138/2024 art. 24 c. 2 lett. d)  | Sicurezza catena di approvvigionamento ICT     |
| ISO/IEC 27001:2022 Annex A.5.19-A.5.23 | Information security in supplier relationships |
| Determinazione ACN n. 38565/2025       | MTOM area 8 — Sicurezza fornitori              |
| TD-SGI-PRO070_00 §8                    | Gestione fornitori ICT critici                 |
| TD-SGI-PRO017_00                       | Qualifica fornitori (versione SGI generale)    |

## 3. Criteri di criticità

Un fornitore ICT è classificato "Critico" se ricorre almeno uno dei seguenti elementi:

- (a) eroga servizi essenziali al funzionamento dei sistemi NIS-soggetti (LIS, RIS, PACS, refertazione, conservazione sostitutiva, datacenter primario);
- (b) tratta dati personali di pazienti come responsabile del trattamento ex art. 28 GDPR;
- (c) ha accesso privilegiato (admin, root, service-account) ai sistemi clinici di TD;
- (d) un'eventuale indisponibilità prolungata (>4 ore) genera impatto operativo significativo sulla continuità diagnostica;
- (e) la sua compromissione potrebbe innescare una notifica obbligatoria al CSIRT Italia o al Garante.

Le ulteriori categorizzazioni sono "Rilevante" (impatto medio, dipendenza non critica) e "Standard" (servizio commodity sostituibile).

## 4. Tabella di inventario

Una riga per fornitore. La tabella è tipicamente più ampia: di seguito l'estrazione delle voci anagrafiche e di qualificazione minime previste dalla PRO070 §8. La versione operativa è mantenuta in formato xlsx con colonne aggiuntive (referente commerciale TD, costo annuo, data ultimo audit, esito).

| Voce            | Descrizione                 |
|-----------------|-----------------------------|
| Ragione sociale | Denominazione completa      |
| P.IVA / VAT     | Codice fiscale o VAT estero |

**Toscana Diagnostica S.r.l.**

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.  
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

|                                            |                                                              |
|--------------------------------------------|--------------------------------------------------------------|
| Sede legale                                | Indirizzo + paese di stabilimento                            |
| Servizio erogato                           | Descrizione sintetica + perimetro contrattuale               |
| Tipologia                                  | SaaS / IaaS / PaaS / On-prem / Servizio gestito / Consulenza |
| Sistemi TD coinvolti                       | Es. LIS, PACS, AD, mail, rete, fisico                        |
| Sub-fornitori (4-th party)                 | Lista dei sub-responsabili dichiarati                        |
| Localizzazione dati                        | Paesi UE / extra-UE; clausole SCC se applicabili             |
| Data inizio rapporto                       | gg/mm/aaaa                                                   |
| Data scadenza/rinnovo                      | gg/mm/aaaa                                                   |
| Criticità (Critico / Rilevante / Standard) | Cfr. §3                                                      |
| Certificazioni del fornitore               | ISO 27001 / SOC 2 / ISO 22301 / ISO 27701 / ISO 13485 / IVDR |
| Validità certificazioni                    | Data scadenza per ciascuna certificazione                    |
| Audit di terza parte                       | Data ultimo audit, owner, esito                              |
| Data Processing Agreement                  | Sì/No, data, riferimento documento                           |
| Clausole NIS2 contrattuali                 | Sì/No (cfr. §9 PRO070 — 8 clausole minime)                   |
| Notifica incidenti < 4 ore                 | Sì/No, riferimento clausola                                  |
| Right-to-audit                             | Sì/No, modalità                                              |
| Exit strategy / Continuity                 | Sì/No, RTO/RPO, plan documentato                             |
| Cyber Insurance del fornitore              | Sì/No, massimale                                             |
| Owner interno TD                           | Funzione/persona di riferimento                              |
| Stato fornitura                            | Attivo / In phase-out / Cessato                              |

## 5. Inventario corrente — Fornitori ICT (estratto)

Inventario ridotto alle voci più rilevanti. Il dato completo è mantenuto nel foglio di lavoro xlsx interno gestito dall'IT Manager (cartella SGI > Sistemi Informativi > NIS2 > Fornitori).

| Fornitore               | Servizio                                               | Tipologia        | Criticità | Cert. principale      | Owner TD   |
|-------------------------|--------------------------------------------------------|------------------|-----------|-----------------------|------------|
| [Provider LIS]          | Laboratory Information System (LIS) — gestione referti | SaaS             | Critico   | ISO 27001             | IT Manager |
| [Provider RIS/PACS]     | Sistema RIS/PACS Diagnostica per Immagini              | SaaS             | Critico   | ISO 27001 + ISO 13485 | IT Manager |
| [Datacenter primario]   | Hosting infrastruttura on-prem + colocation            | IaaS             | Critico   | ISO 27001 + ISO 22301 | IT Manager |
| [Provider Cloud backup] | Backup off-site + cifratura at-rest                    | SaaS             | Critico   | ISO 27001             | IT Manager |
| [Provider Mail/M365]    | Posta elettronica + collaboration                      | SaaS             | Rilevante | ISO 27001 + SOC 2     | IT Manager |
| [MSSP / SOC]            | Managed Security / SOC 24x7                            | Servizio gestito | Critico   | ISO 27001             | IT Manager |
| [Connettività]          | Connettività Internet primaria/secondaria              | Telco            | Critico   | ISO 27001             | IT Manager |
| [Provider Endpoint EDR] | Endpoint Detection & Response                          | SaaS             | Critico   | SOC 2                 | IT Manager |
| [Servizi]               | Manutenzione                                           | On-site          | Rilevante | —                     | IT         |

|                                |                                               |         |           |                  |                         |
|--------------------------------|-----------------------------------------------|---------|-----------|------------------|-------------------------|
| assistenza HW]                 | strumentazione di laboratorio (parte ICT)     |         |           |                  | Manager + Direttore Lab |
| [Conservazione sostitutiva]    | Conservatore digitale a norma                 | SaaS    | Critico   | AgID + ISO 27001 | DPO + IT Manager        |
| [Sistemi POS/Cassa]            | Pagamenti integrati con LIS/Accettazione      | SaaS    | Rilevante | PCI-DSS          | IT Manager              |
| [Diagnostica IVD — middleware] | Middleware analitico fra strumentazione e LIS | On-prem | Critico   | ISO 13485 + IVDR | Direttore Lab           |

Le voci tra parentesi quadre saranno sostituite con le ragioni sociali effettive in sede di prima compilazione operativa, entro il 31/05/2026.

## 6. Indicatori di processo

| KPI                                                       | Formula                                                  | Target                                              |
|-----------------------------------------------------------|----------------------------------------------------------|-----------------------------------------------------|
| % fornitori critici con clausole NIS2 contrattuali        | $(N \text{ con clausole } 8/8) / (N \text{ critici})$    | $\geq 90\%$ entro 31/12/2026; 100% entro 30/06/2027 |
| % fornitori critici con ISO 27001 valida                  | $(N \text{ con cert. valida}) / (N \text{ critici})$     | $\geq 80\%$                                         |
| % audit fornitori critici eseguiti nell'anno              | $(N \text{ audit eseguiti}) / (N \text{ critici})$       | $\geq 30\%$ /anno (rotazione triennale)             |
| % fornitori critici con DPA in vigore                     | $(N \text{ con DPA}) / (N \text{ critici e treat.dati})$ | 100%                                                |
| Tempo medio di chiusura non conformità da audit fornitore | $\Sigma (T_{\text{chiusura}} - T_{\text{audit}}) / N$    | $\leq 90$ giorni                                    |

## 7. Storico delle revisioni

| Rev. | Data       | Descrizione                                                                         | Redatto           | Approvato |
|------|------------|-------------------------------------------------------------------------------------|-------------------|-----------|
| 00   | 29/04/2026 | Prima emissione dell'inventario fornitori ICT in attuazione di TD-SGI-PRO070_00 §8. | IT Manager / RSGI | AD        |